NATIONAL FORENSIC SCIENCE UNIVERSITY, DELHI

P3: VULNERABILITY ASSESSMENT AND PENETRATION TESTING

SQL Injection analysis using DVWA and SQL Map

Aim

To identify, demonstrate, and analyze an SQL Injection vulnerability in the Damn Vulnerable Web Application (DVWA) using a controlled local laboratory environment and SQL Map.

Theory

SQL Injection is a web application vulnerability that occurs when untrusted user input is incorporated into an SQL query without proper validation or parameterisation. An attacker may manipulate the input so that the application executes an unintended SQL query, potentially exposing or modifying database information.

DVWA (Damn Vulnerable Web Application) is an intentionally vulnerable web application developed for security testing and learning. In this practical, DVWA is hosted in a local Docker environment and accessed through the loopback address. The SQL Injection module is used to observe how the User ID parameter interacts with the database.

SQL Map is a penetration-testing tool used to detect SQL injection vulnerabilities and enumerate database information. In the controlled DVWA environment, it can identify injectable parameters, determine the database management system, enumerate databases and tables, and retrieve records.

Tools / Environment Used

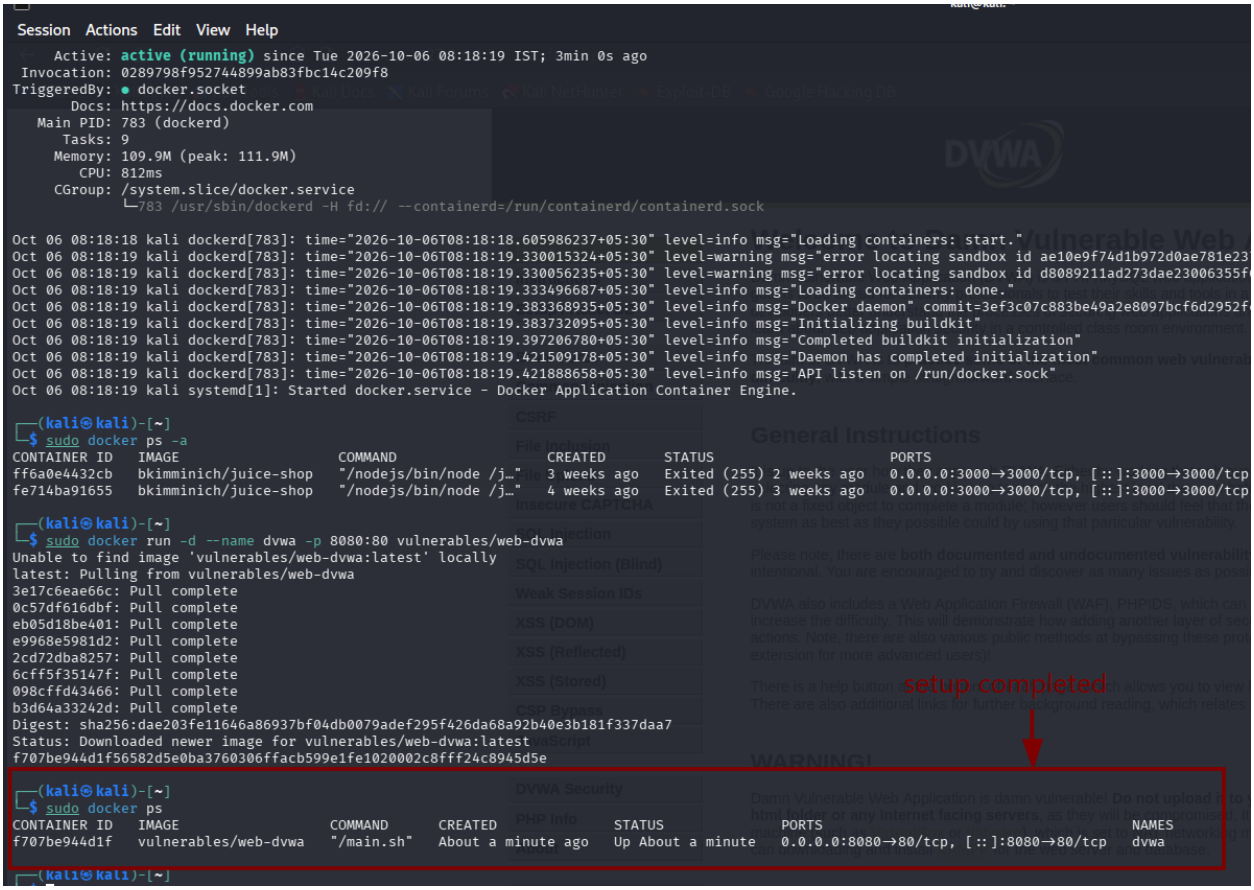
1. Kali Linux
2. Docker
3. Damn Vulnerable Web Application (DVWA)

4. Mozilla Firefox
5. SQL Map
6. Localhost / loopback address (127.0.0.1)

Procedure

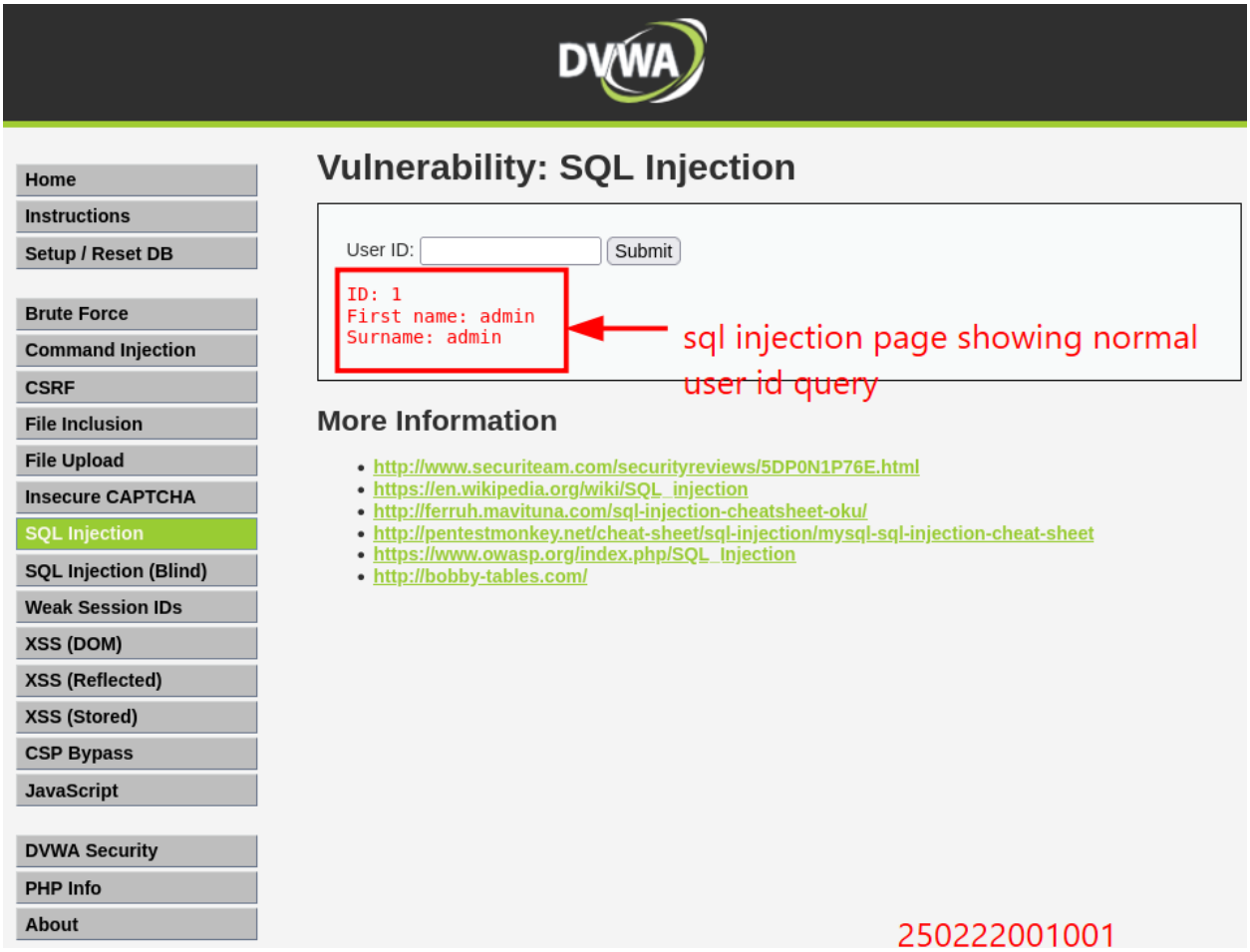
A. Setting Up DVWA

1. Start the Docker service in Kali Linux.
2. Check that the Docker is running correctly.
3. Pull and start the DVWA Docker container.
4. Map the required local port to the DVWA container.
5. Open DVWA through the local browser address.
6. Complete the required DVWA setup and database configuration.



B. Accessing the SQL Injection Module

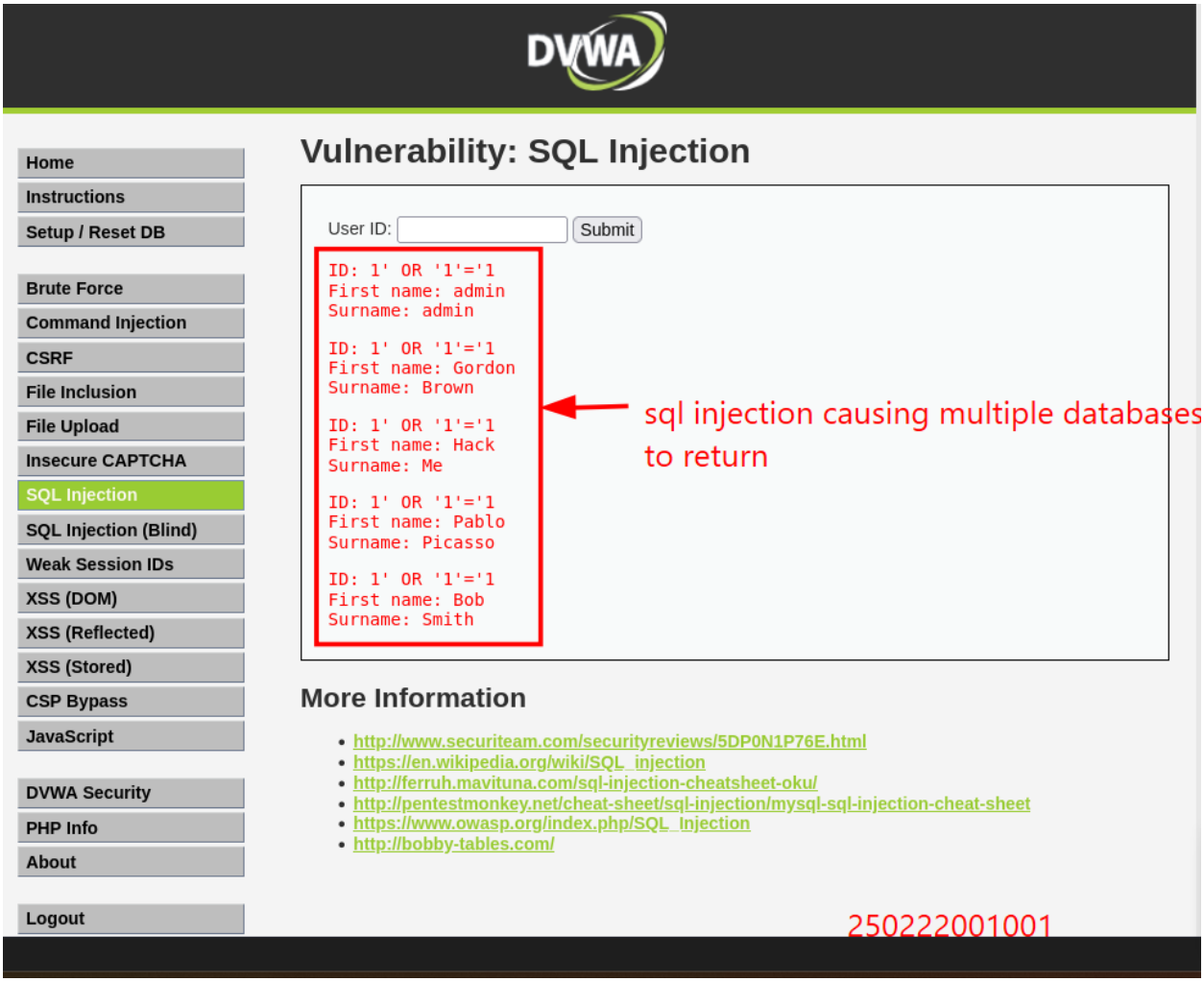
1. Log in to DVWA.
2. Open the **SQL Injection** module from the vulnerability menu.
3. Enter a normal User ID value.
4. Observe the information returned by the application.
5. Note that the User ID is being used to retrieve information from the database.



C. Demonstrating SQL Injection

1. Enter a Boolean-based SQL injection input into the User ID field.
2. Submit the input in the controlled DVWA environment.
3. Observe the application response.
4. If multiple records are returned instead of a single expected record, note the behaviour.

5. This demonstrates that the supplied input is being interpreted as part of the SQL query.



D: Prepare SQLMap

1.SQLMap is used to automate testing of the local DVWA SQL Injection page.

Check whether SQLMap is installed. If it is missing, install it.

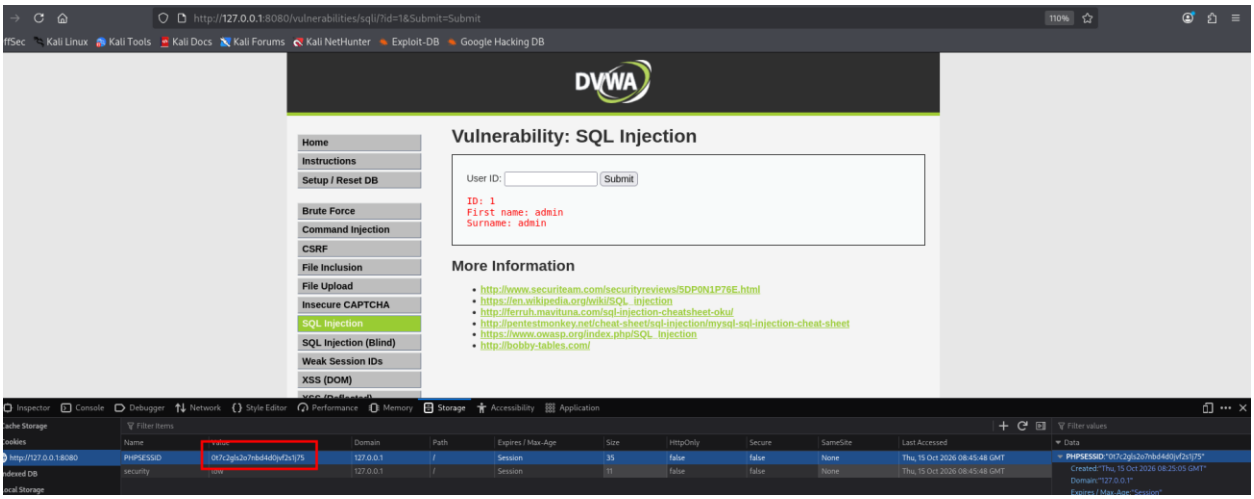
2.Open the SQL Injection page in Firefox first. The PHPSESSID session cookie allows SQLMap to use your authenticated DVWA session.

3. Find the PHP session cookie.

In Firefox:

- Press F12 to open Developer Tools.

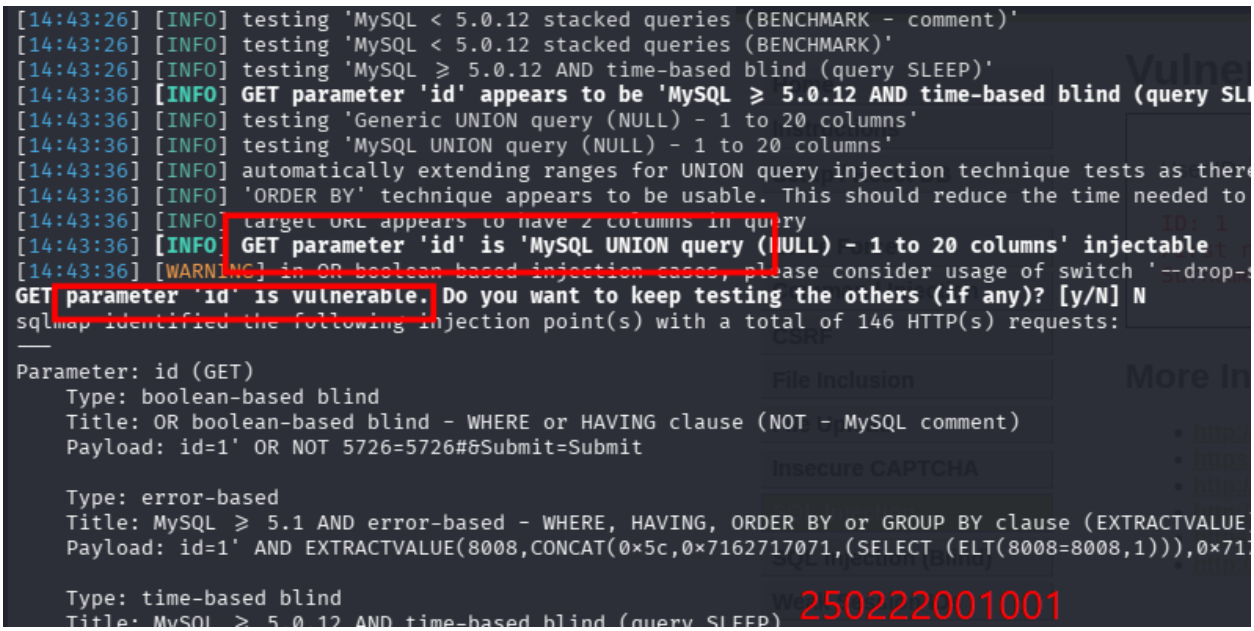
- Open the Storage tab (or the browser's Cookies storage section).
- Expand Cookies and select http://127.0.0.1:8080.
- Find PHPSESSID and copy its value.
- Check the DVWA Security page to ensure the security level is low.



E: Detect the SQL Injection vulnerability using SQLMap

1. Run SQLMap against the local DVWA URL.

Replace YOUR_SESSION_ID with the actual PHPSESSID value copied from Firefox.



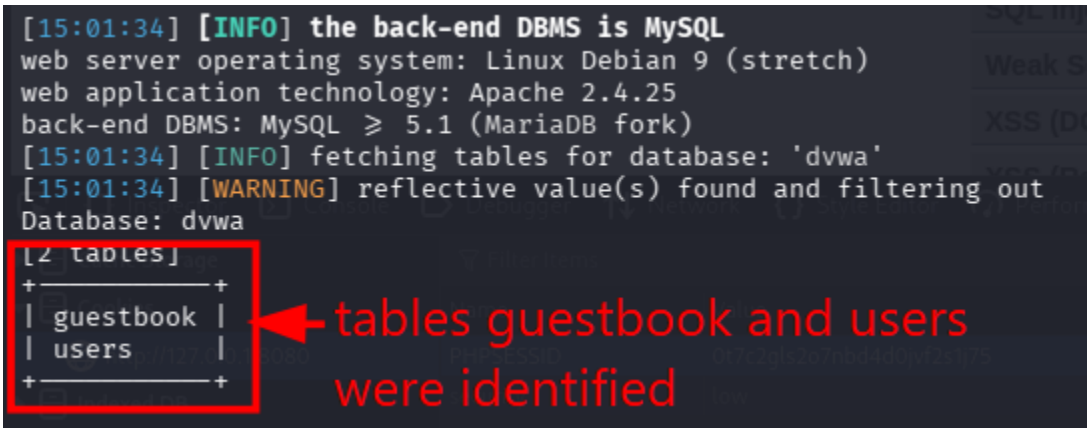
F: Enumerate the database

1. List the databases.

Use the same URL and session cookie

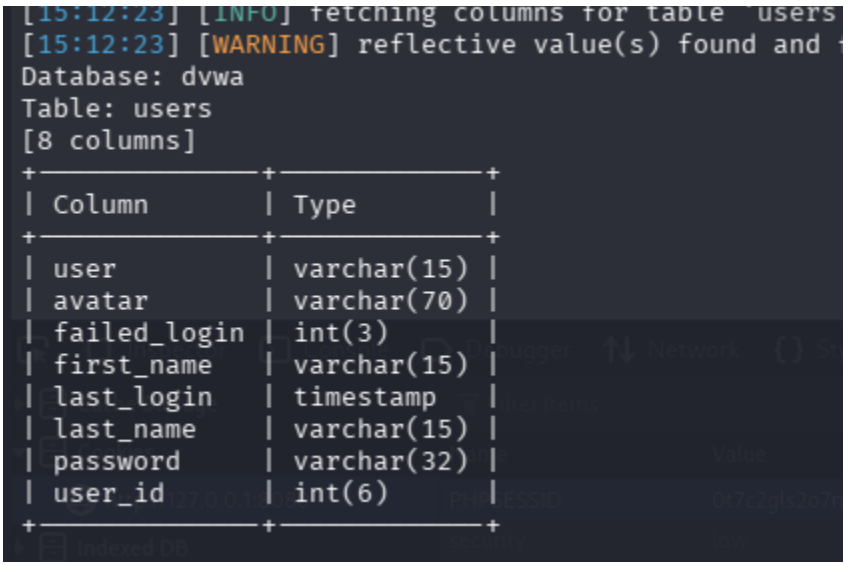
Look for the dvwa database in the output

2. List the tables in the DVWA database.



G: Examine the users table

1.List the columns of the users table.



Retrieve the lab's demonstration records.

Only perform this step against your own isolated DVWA instance, using its deliberately created sample data.



H: Demonstrate SQL Injection (Blind)

1.Open the Blind SQL Injection module.

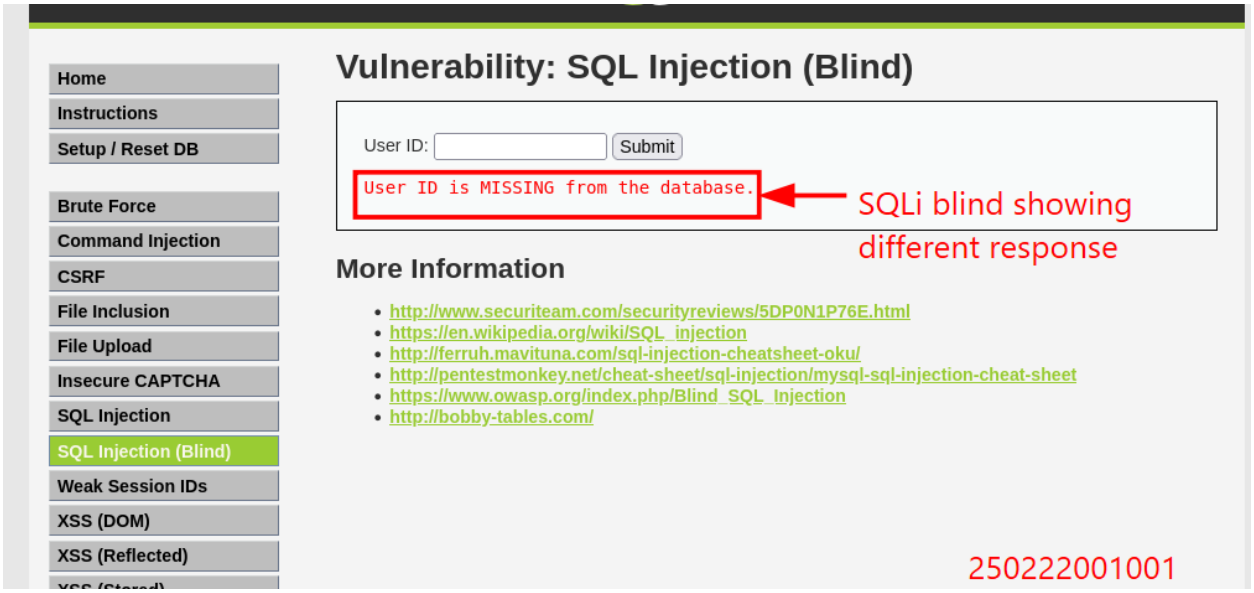
In Firefox, select SQL Injection (Blind) from the DVWA menu.

2. Submit a normal User ID.

Enter 1 and submit it. Note the response message.

3. Compare responses.

Try another ordinary ID, such as 9999, and submit it. Compare the responses.



Observations

The DVWA SQL Injection module accepted user-controlled input through the User ID parameter. A Boolean-based test input could cause multiple records to be returned, demonstrating SQL Injection in the configured vulnerable application. SQLMap was then used to test the parameter and inspect the database structure. The supplied practical reports the dvwa database, the `guestbook` and `users` tables, and five entries in the `users` table. The Blind SQL Injection module demonstrated how application responses can reveal whether a particular user ID exists.

Result

SQL Injection testing was performed in a controlled DVWA environment. The vulnerable parameter was examined manually and with SQLMap, and the database structure was investigated. The exercise demonstrated the security risks associated with incorporating untrusted input into SQL queries.

Applications in Digital Forensics

1. Identifying web application vulnerabilities that could expose database information.
2. Understanding how malicious input can alter database queries.
3. Investigating potential database exposure caused by vulnerable applications.
4. Examining database and application behaviour during security investigations.
5. Documenting testing results for technical analysis.
6. Understanding the importance of input validation and parameterised queries.

Precautions

1. Perform testing only on systems for which you have permission.
2. Keep DVWA isolated in a local laboratory environment.
3. Do not expose the intentionally vulnerable application to the public Internet.
4. Never share session cookies or authentication details.
5. Preserve relevant evidence and document results accurately.
6. Use parameterized queries and appropriate input handling when developing real applications.